

Plantilla de Reporte Ejecutivo en PowerPoint (versión KEV)

Esta plantilla describe la estructura recomendada de una presentación ejecutiva para exponer los resultados de la encuesta KEV + GQM + PRAGMATIC ante dirección general, comités de riesgo o foros sectoriales.

Cada sección corresponderá normalmente a una o varias diapositivas.

Diapositiva 1. Portada

- Título sugerido: «Diagnóstico de Madurez en Gestión de Vulnerabilidades KEV y Resiliencia Digital».
- Subtítulo: «Resultados de la encuesta organizativa / sectorial».
- Datos: nombre de la organización(es), fecha, área responsable.

Opcional: breve claim como «De los CVE al riesgo real: cómo nos afectan las KEV».

Diapositiva 2. Resumen ejecutivo

Objetivo: que alguien que solo vea esta diapositiva entienda lo esencial.

Elementos:

- 3–5 mensajes clave, por ejemplo:
- Nivel global de madurez (IGM) y nivel cualitativo (Inicial, Básico, Definido, Gestionado, Optimizado).
- 2–3 fortalezas (por ejemplo, buena capacidad de detección, programas de formación consolidados).
- 2–3 áreas críticas (por ejemplo, lentitud en remediar KEV, inventarios incompletos, baja integración de KEV en el SOC).
- Gráfico simple (barra o velocímetro) mostrando el IGM global.

Estilo: directo, orientado a negocio, sin jerga innecesaria.

Diapositiva 3. Contexto y objetivos

Contenido sugerido:

- Breve explicación del contexto externo:
- Tendencias de KEV (crecimiento del catálogo, foco en perímetro, impacto en ransomware, etc.).
- Referencias a marcos (NIS2, ENS, ENISA, CISA KEV).
- Objetivos de la evaluación:
- Medir la madurez en gestión de vulnerabilidades y KEV.
- Identificar brechas y priorizar inversiones.
- Establecer una línea base para seguimiento.

Gráfico opcional: línea de tiempo o esquema de las «capas» del modelo (GQM, PRAGMATIC, encuesta, indicadores KEV).

Diapositiva 4. Metodología

Contenido:

- Resumen del enfoque GQM:
- Objetivos – Preguntas – Métricas.
- Uso de PRAGMATIC para filtrar métricas.
- Información práctica:
- Nº de organizaciones participantes.
- Perfiles de respuesta (CISO, TI, SOC, etc.).
- Periodo de recogida.

Gráfico sugerido: diagrama de flujo sencillo con las fases: **Encuesta – IGM/Indicadores KEV – Análisis – Recomendaciones.**

Diapositiva 5. Índice Global de Madurez (IGM)

Elementos:

- Gráfico principal: velocímetro o barra con el IGM en escala 0–100.
- Nivel cualitativo asociado (por ejemplo, «Nivel 3 – Definido»).
- Breve interpretación:
- Qué significa estar en ese nivel.
- Qué se esperaría en el nivel superior.

Diapositiva 6. Madurez por dimensión

Contenido:

- Gráfico radar o barras comparando:
- IGM_GOV (Gobierno).
- IGM_VUL (Gestión de vulnerabilidades y KEV).
- IGM_PEN (Pentesting).
- IGM_SIEM (Monitorización y detección).
- IGM_AWR (Capacitación y cultura).
- IGM_MET (Métricas y ROI).

Comentarios:

- Dimensiones por encima de la media (fortalezas).
- Dimensiones por debajo de la media (oportunidades claras de mejora).

Diapositivas 7–8. Foco en Gobernanza y Estrategia (GOV)

Elementos posibles:

- % de organizaciones con política formal que menciona KEV.
- % con roles definidos y SLAs específicos de remediación.
- Frecuencia declarada de revisión del catálogo KEV.

Gráficos: barras apiladas por nivel de madurez en GOV-01, GOV-02, GOV-04.

Mensaje clave: grado de «institucionalización» de la gestión de KEV.

Diapositivas 9-10. Foco en Gestión Operativa de Vulnerabilidades y KEV (VUL)

Elementos:

- Nivel de inventario de activos.
- Uso de escáneres con etiquetado KEV.
- Medición de tiempos de remediación y % de KEV en plazo.
- Tratamiento diferenciado de dispositivos perimetrales y sistemas legacy.

Gráficos recomendados:

- Barras para VUL-01, VUL-02, VUL-04.
- Tabla/resumen con indicadores agregados KEV:
- % de organizaciones con ≥ 1 KEV abierta.
- Densidad media de KEV.
- Mediana de días de remediación KEV (si se dispone de datos).

Mensaje clave: qué tan controlada está la «superficie KEV» del parque tecnológico.

Diapositiva 11. Pruebas de penetración y ejercicios (PEN)

Contenido:

- Frecuencia de pentests.
- Integración de KEV en el alcance de pruebas.
- Presencia de ejercicios Red/Purple Team.
- Gestión de hallazgos.

Gráficos: barras para PEN-01, PEN-02, PEN-04.

Narrativa: diferencia entre pentests «cosméticos» y pruebas alineadas con amenazas reales.

Diapositivas 12-13. Monitorización, SIEM y detección (SIEM)

Elementos:

- Situación SIEM/SOC (inexistente, parcial, 24x7 interno/externo).
- Casos de uso específicos para explotación de vulnerabilidades.
- Integración de inteligencia de amenazas/KEV.
- Uso de detección basada en comportamiento.

Gráficos posibles:

- Diagrama de barras SIEM-01 (situación actual de SOC).
- Gráfico de columnas agrupadas para SIEM-02, SIEM-04, SIEM-05.

Mensaje clave: capacidad real de «ver y entender» cuando se explota una KEV.

Diapositiva 14. Capacitación y cultura (AWR)

Contenido:

- Existencia de programa de formación general.
- Formación técnica específica en vulnerabilidades/KEV.
- Simulaciones y cultura de reporte.

Gráficos: barras para AWR-01, AWR-02, AWR-03, AWR-04.

Narrativa: el factor humano como amortiguador o amplificador del riesgo técnico.

Diapositiva 15. Métricas y ROI (MET)

Elementos:

- Indicadores sobre vulnerabilidades/KEV (MET-01).
- Indicadores sobre pentesting y SIEM (MET-02).
- Uso de benchmarks externos (MET-03).
- Prácticas de cálculo de ROI (MET-04).

Gráfico: tabla resumen con niveles de madurez MET, más uno o dos ejemplos de iniciativas con mejor ROI estimado.

Mensaje: pasar de «gastos necesarios» a **inversiones justificadas** en seguridad.

Diapositiva 16. Indicadores KEV nacionales clave (si aplica a estudio sectorial/país)

Contenido:

- % de organizaciones evaluadas con ≥ 1 KEV abierta (E1).
- Densidad media de KEV por organización (E2).
- Mediana de días de remediación KEV (R1).
- % de KEV remediadas dentro del plazo objetivo (R2).

Gráficos: 2–3 gráficas sencillas (barras, caja y bigotes para tiempos, etc.).

Narrativa: conectar la foto del sector/país con benchmarks globales.

Diapositivas 17–18. Priorización de iniciativas

Propuesta de 4–6 iniciativas ordenadas según impacto y esfuerzo (o ROI).

Tabla sugerida:

- Iniciativa.
- Dimensión principal (GOV, VUL, SIEM, etc.).
- Impacto esperado.
- Esfuerzo/coste.
- ROI estimado (si se ha calculado).

Gráfico posible: matriz impacto/esfuerzo (Quick wins, Proyectos estratégicos, etc.).

Diapositivas 19-20. Roadmap de mejora

Contenido:

- Roadmap en tres horizontes:
- Corto plazo (0-12 meses): acciones urgentes y quick wins.
- Medio plazo (1-2 años): consolidación y automatización.
- Largo plazo (>2 años): optimización, analítica avanzada, alineamiento pleno con negocio.

Gráfico: diagrama de Gantt de alto nivel o roadmap en formato carril (por dimensión).

Diapositiva final. Conclusiones y próximos pasos

Elementos:

- 3-5 conclusiones clave.
- 3-5 próximos pasos concretos (por ejemplo, «definir plan KEV de país», «implantar SLAs mínimos por sector», «repetir encuesta en 18 meses»).

Cierre sugerido:

- Mensaje positivo, realista y ligeramente irónico: «Las KEV seguirán llegando; la diferencia entre titular de incidente y caso de éxito depende de lo que hagamos entre tanto».

Con esta plantilla, los resultados de la encuesta dejan de ser un anexo inerte en formato tabla y se convierten en una historia coherente: dónde estamos, qué riesgos reales afrontamos por culpa (o gracias) a las KEV, qué podemos hacer y por qué merece la pena empezar cuanto antes.